Penetration Testing Report

Foot printing, OSINT and Network Discovery (Week 2)

Field	Details
Student	Mulenga Chiwele
Program / Batch	Networkwalks Internship, BO83
Date	13 November 2026
Modules	PM1, PM2, PM3, PM4, PM5
Authorized targets	networkwalks.com (written permission stated); own virtual LAN 192.168.122.0/24

Testing was limited to explicitly authorized systems and passive public-source research. No exploitation was performed.

1. Liability, Authorization and Ethics

All activities in this report were carried out for education and research. Active reconnaissance was limited to networkwalks.com, under the permission stated by the student, and to the student's own virtual LAN. No exploitation, password testing, authentication bypass, persistence, or destructive activity took place.

For the camera-related GHDB exercise, public indexing was not treated as authorization. One potentially accessible WebcamXP listing was observed, and interaction stopped immediately. The camera was not controlled, authenticated to, recorded, or included as a live target. Ten third-party cameras were not validated because written authorization from their owners was unavailable. This limitation follows professional ethical-testing practice.

2. Executive Summary

This Week 2 project covered reconnaissance, open-source intelligence and local network discovery. PM1 used WHOIS, WhatWeb, Nslookup, Curl, Wafw00f and DNSRecon against the authorized Networkwalks domain. PM2 demonstrated Google search operators for educational PDFs and reviewed camera-exposure methodology within strict ethical limits. PM3 used Maltego to identify a public organizational email address. PM4 used theHarvester against microsoft.com, as the assignment specified. PM5 replaced Zenmap with its command-line engine, Nmap, to discover hosts on the student's own virtual LAN.

The work identified publicly visible infrastructure and technology information. These observations are not proof of exploitable vulnerabilities. The most important lesson was that accessible or indexed information does not remove the need for authorization, careful evidence handling and responsible disclosure.

3. Scope and Limitations

Area	In scope	Limitations
PM1	Authorized public-facing networkwalks.com reconnaissance	No exploitation or intrusive vulnerability testing

Area	In scope	Limitations
PM2	Google/GHDB methodology and educational PDF discovery	No continued access to or validation of third-party cameras; identifying device data excluded
PM3	Public email transforms for networkwalks.com	Community Edition and search-engine data limitations
PM4	Passive the Harvester queries for microsoft.com	Many sources require API keys; source behavior changes over time
PM5	Host discovery on 192.168.122.0/24	Virtual LAN only; -sn host discovery, no port scan

4. Tools Used

Tool	Purpose
Kali Linux	Testing workstation
WHOIS	Domain registration and nameserver information
WhatWeb	Web-technology fingerprinting
Nslookup	DNS name resolution
Curl -I	HTTP response headers
Wafw00f	WAF identification
DNSRecon	DNS record enumeration
Google/GHDB	Search-operator-based OSINT
Maltego Graph 4.13.0	Entity and public email relationship mapping
theHarvester 4.11.1	Passive host, IP and email collection
Nmap 7.99	Local host discovery using -sn

5. PM1: Footprinting with Multiple Kali Tools

Each tool was run against networkwalks.com. The results describe publicly visible information and do not on their own indicate a vulnerability.

5.1 WHOIS

Command: whois networkwalks.com

Result: GoDaddy.com, LLC is the registrar. The record shows creation on 6 November 2019 and expiry on 6 November 2027, with privacy-protected registration and HostGator nameservers.

5.2 WhatWeb

Command: whatweb networkwalks.com

Result: The site redirects to HTTPS and exposes Apache, WordPress 7.1.1, WP Download Manager 3.3.58, Bootstrap, jQuery, HTML5, Google Tag Manager, Open Graph, and IP 192.232.216.135.

5.3 Nslookup

Command: nslookup networkwalks.com

Result: The domain resolves to 192.232.216.135 through the local resolver 192.168.122.1.

5.4 Curl

Command: curl -I https://networkwalks.com

Result: The server returns HTTP/2 200. Headers identify Apache, a WordPress REST API link under /wp-json/, secure HttpOnly cookie attributes, and cache-related headers.

5.5 Wafw00f

Command: wafw00f networkwalks.com

Result: Wafw00f 2.4.2 identified ModSecurity (SpiderLabs) after two requests.

5.6 DNSRecon

Command: dnsrecon -d networkwalks.com

Result: Enumeration found eight records, including SOA/NS, mail, A, TXT/SPF, and autoconfiguration SRV information. A DNSSEC query returned no answer.

6. PM1 Results at a Glance

Section	Tool	Command	Key result
5.1	WHOIS	whois networkwalks.com	GoDaddy.com, LLC registrar; created 6 Nov 2019, expires 6 Nov 2027; privacy-protected; HostGator nameservers
5.2	WhatWeb	whatweb networkwalks.com	Redirects to HTTPS; Apache, WordPress 7.1.1, WP Download Manager 3.3.58; IP 192.232.216.135
5.3	Nslookup	nslookup networkwalks.com	Resolves to 192.232.216.135 via resolver 192.168.122.1
5.4	Curl	curl -I https://networkwalks.com	HTTP/2 200; Apache; WordPress REST API under /wp-json/; HttpOnly cookies
5.5	Wafw00f	wafw00f networkwalks.com	ModSecurity (SpiderLabs) identified after two requests
5.6	DNSRecon	dnsrecon -d networkwalks.com	Eight records (SOA/NS, mail, A, TXT/SPF, SRV); no DNSSEC answer

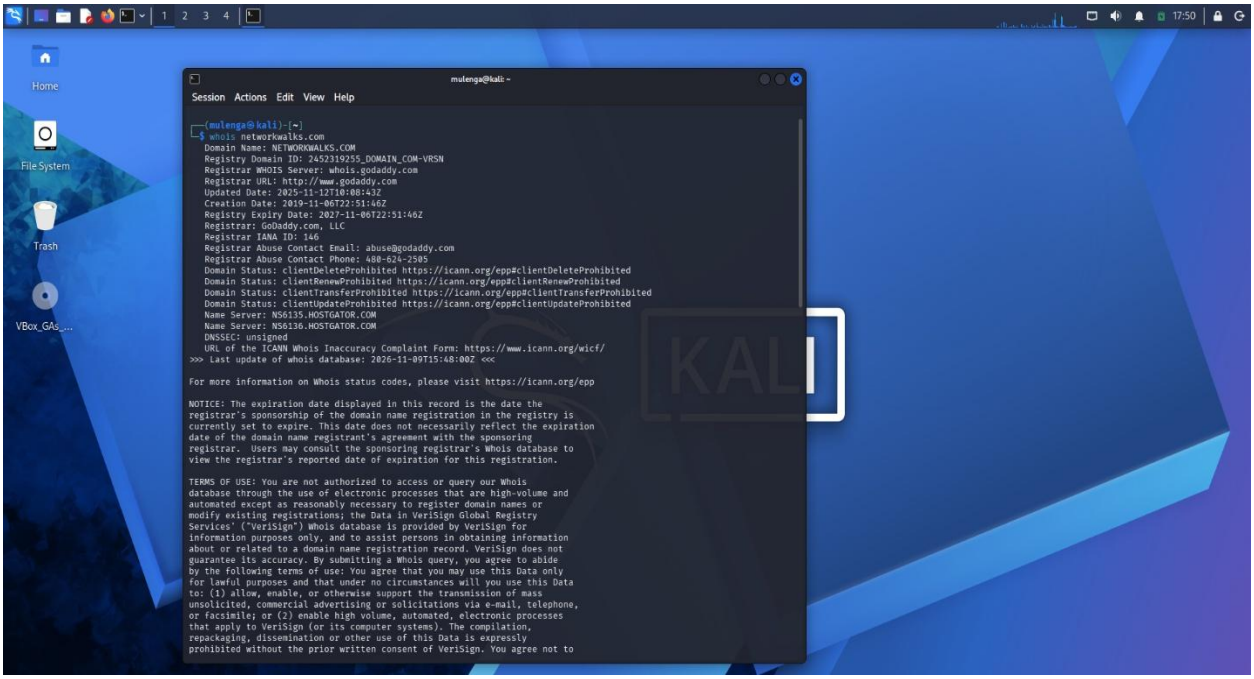


Figure 1 — WHOIS command and key registration data.

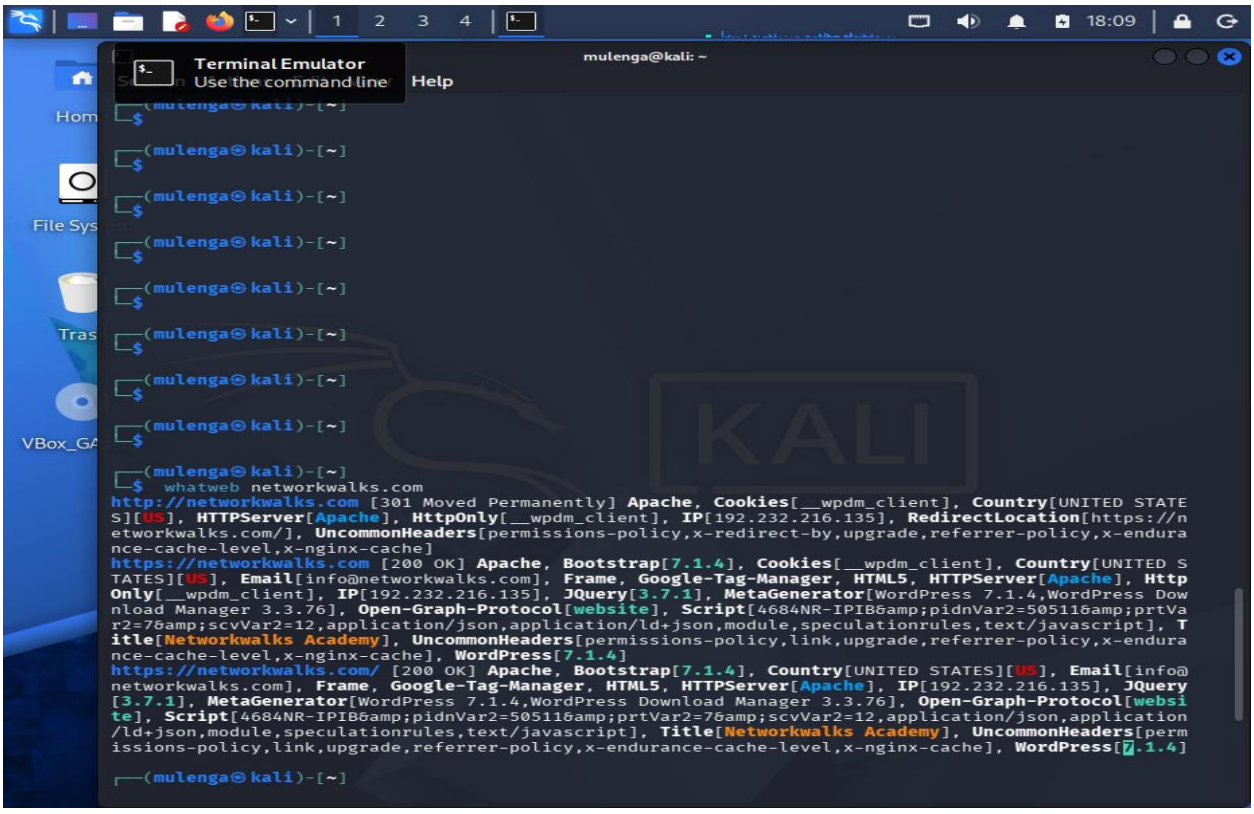


Figure 2 — WhatWeb technology fingerprint

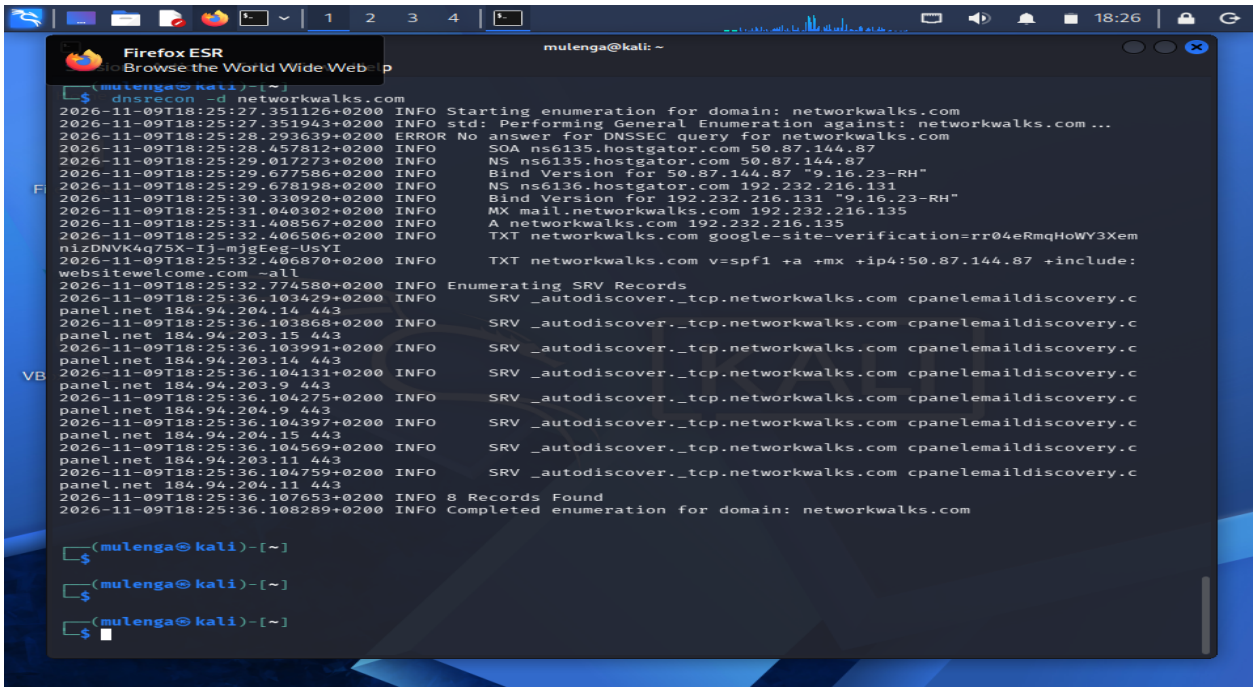


Figure 3 — DNS resolution result.

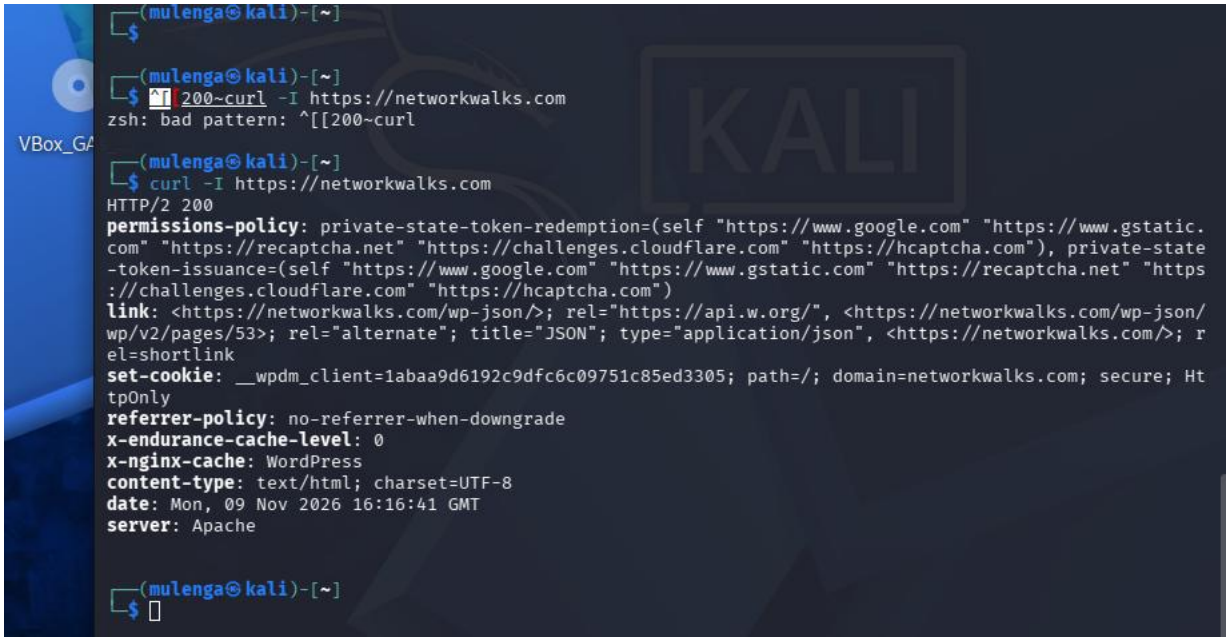


Figure 4 — HTTP response headers.

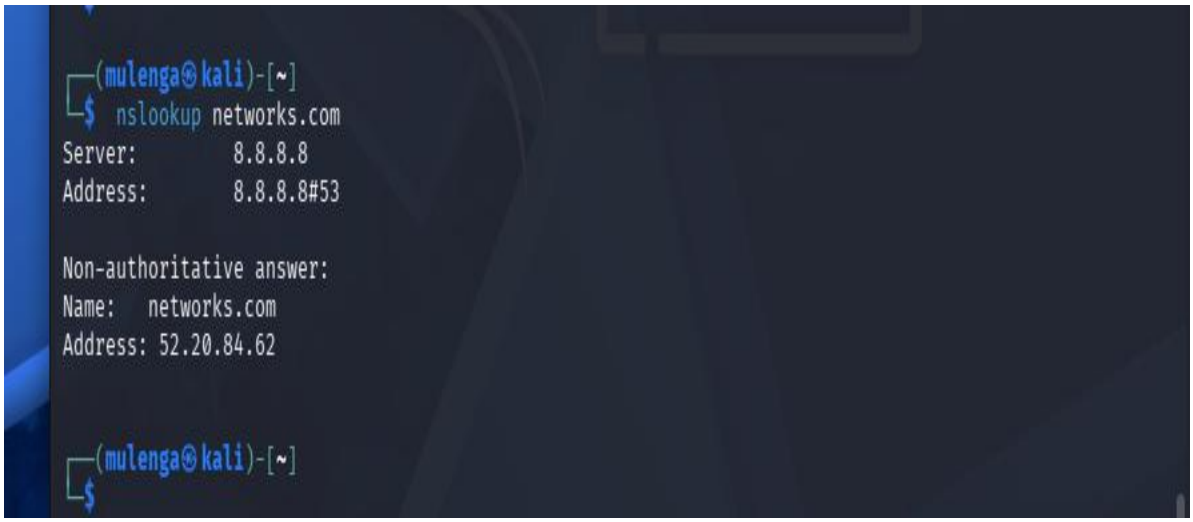


Figure 5 — Nslookup response.

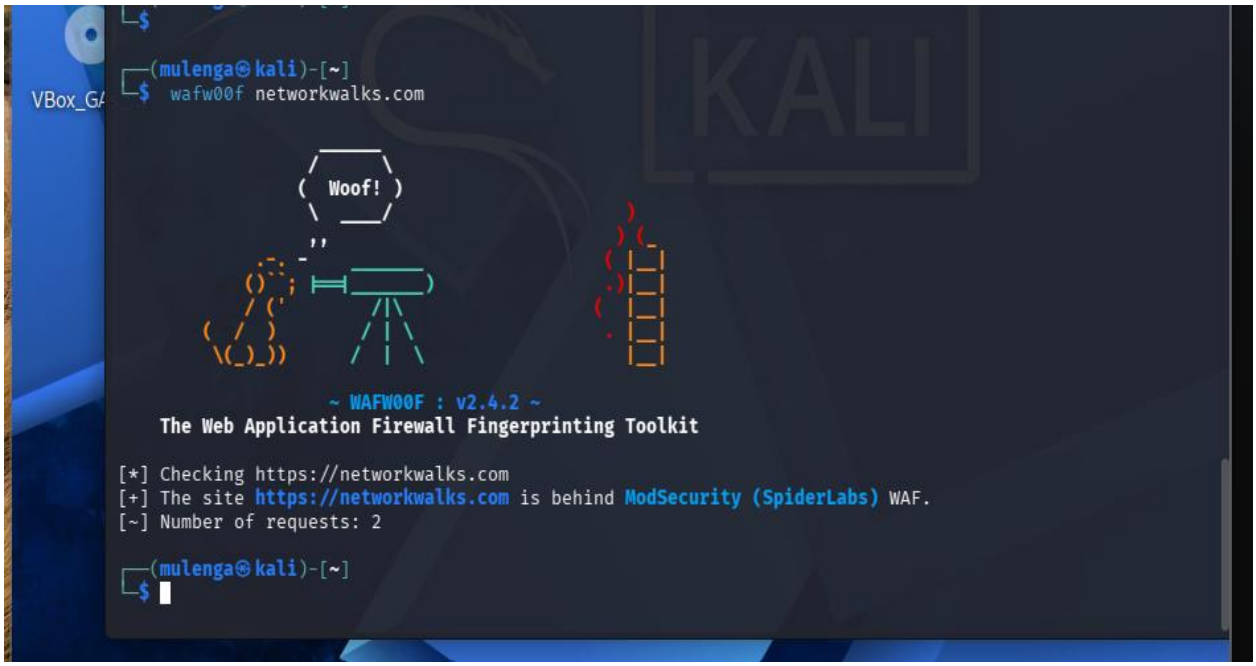


Figure 6 — ModSecurity WAF identification

6. PM2 — GHDB and Search-Based OSINT

6.1 Mathematics PDF listings

Google query used: filetype:pdf mathematics site:edu

No.	Listing Title	Institution / Domain
1	A Short Account of the History of Mathematics	The University of New Mexico (institutional-partnerships.unm.edu)
2	Definition of Mathematics	Illinois Institute of Technology (math.iit.edu)
3	An Introduction to Higher Mathematics	Whitman College (whitman.edu)
4	A Guide to Writing Mathematics	UC Davis (web.cs.ucdavis.edu)
5	The Princeton Companion to Mathematics	Rutgers University (sites.math.rutgers.edu)
6	Mathematics and Its History, Third Edition	University of Illinois Urbana-Champaign (jontallen.ece.illinois.edu)
7	On Proof and Progress in Mathematic	University of Toronto (math.toronto.edu
8	Mathematics in the Middle: The Relationship Between…	Universitat de Barcelona (revistes.ub.edu)

The table records search listings only. Files were not redistributed in the repository, and availability or licensing should be checked with each host before reuse.

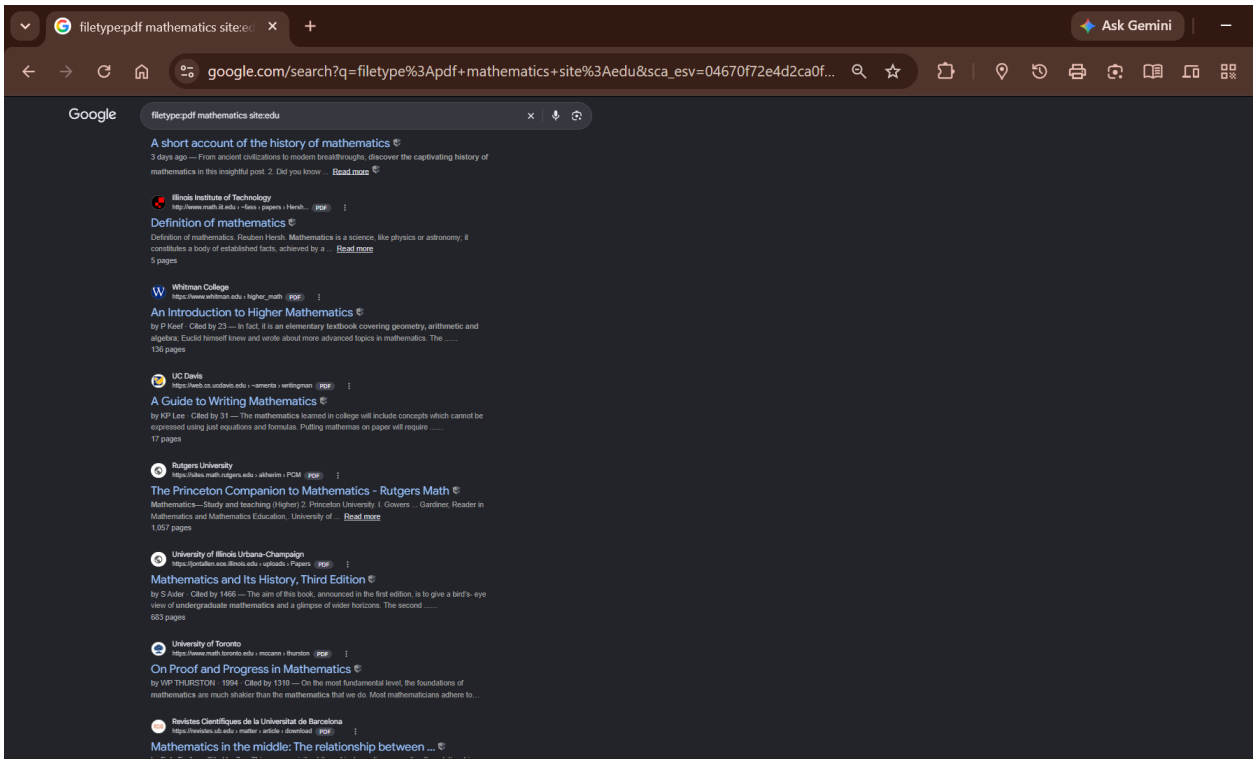


Figure 7 — institutional PDF listings.

6.2 Camera-Related GHDB Methodology and Ethical Limits

The assignment provided the query intitle:"webcamXP" inurl:8080 as an example. Google returned a listing that may be an exposed WebcamXP page. Shodan's aggregate results also showed that device-search engines index internet-facing services. Being indexed, however, does not give permission to view or control a camera. I stopped further validation, left out identifying details, and did not collect the ten live camera links the assignment asked for, because each camera would need its owner's authorization.

Requested item	Documented outcome
Ten live camera links	Not collected or published without each owner's authorization
Dork methodology	Demonstrated with the assignment-provided WebcamXP query
Credentials	None tested, collected, or reported
Recommended safe substitute	Instructor-controlled cameras, honeypots, or written authorization for ten lab targets

7. PM3: Footprinting with Maltego

Maltego Graph Desktop 4.13.0 Community Edition was configured for this exercise, and a Domain entity was changed from the default maltego.com to networkwalks.com. Running the "To Email Addresses [Search Engine]" and "To Emails @domain [Search Engine]" Utilities transforms returned one unique public organizational address, info@networkwalks.com, while the second transform added no new addresses. Because search-engine transforms can return stale or incomplete data, any address they find should be verified through authorized channels before it is relied on.

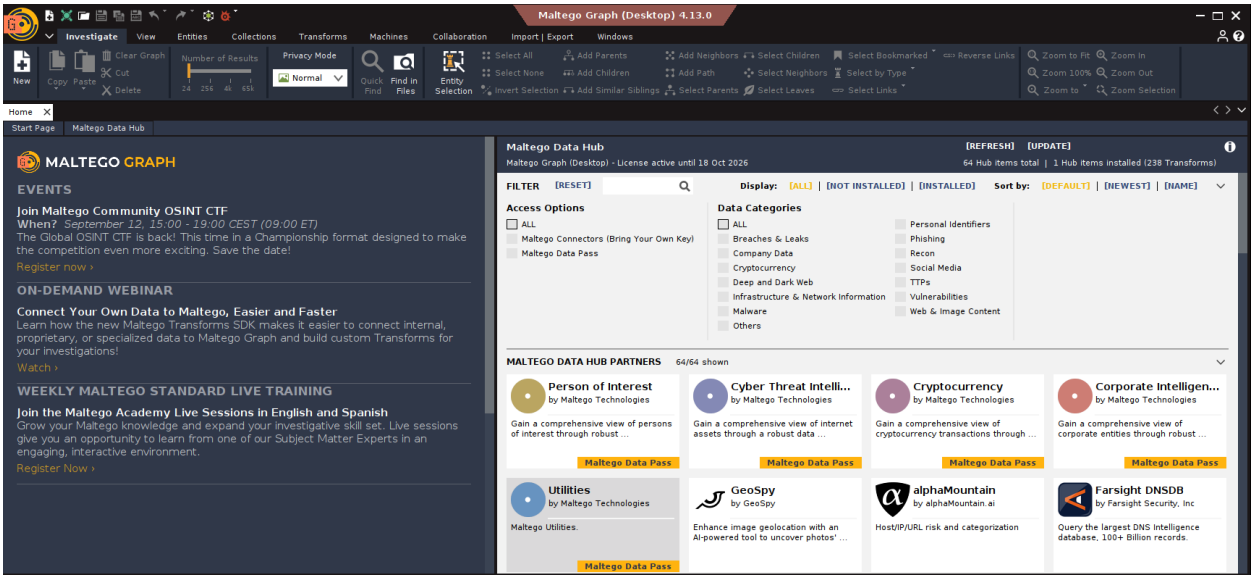


Figure 8 — Maltego installation and active workspace.

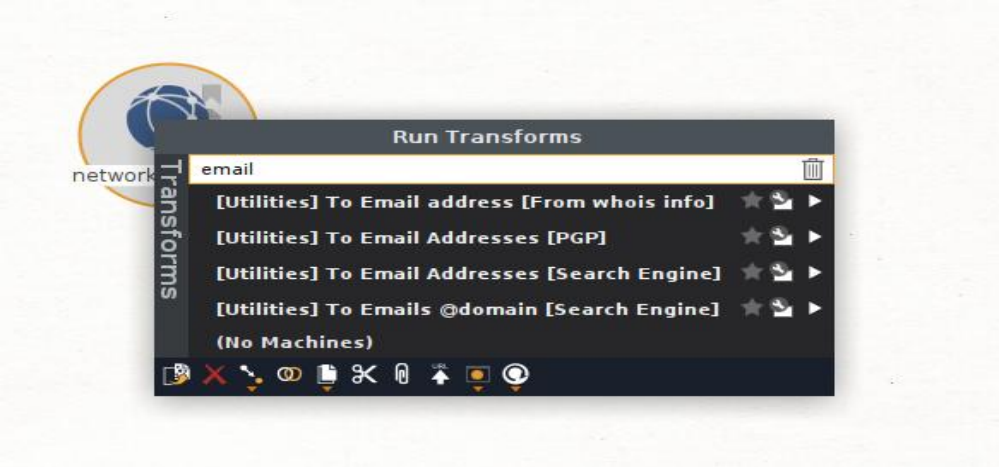


Figure 9 — Email-related transforms selected for the domain entity.

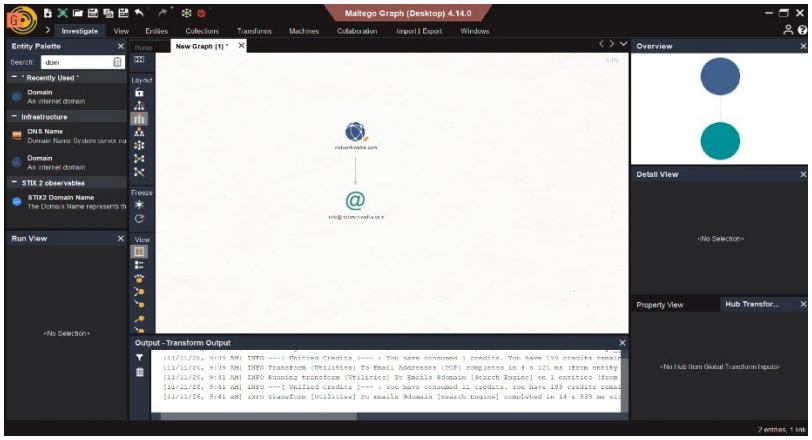


Figure 10 — Final Maltego graph and transform output.

8. PM4 — Footprinting with theHarvester

8.1 Baidu source, limit 1000

Command: theHarvester -d microsoft.com -l 1000 -b baidu
Result: theHarvester 4.11.1 completed the Baidu query but returned no IPs, emails, people or hosts. This was retained as an honest current result because third-party source behavior and parsers change over time.



Figure 11— Baidu-source query and zero-result outcome.

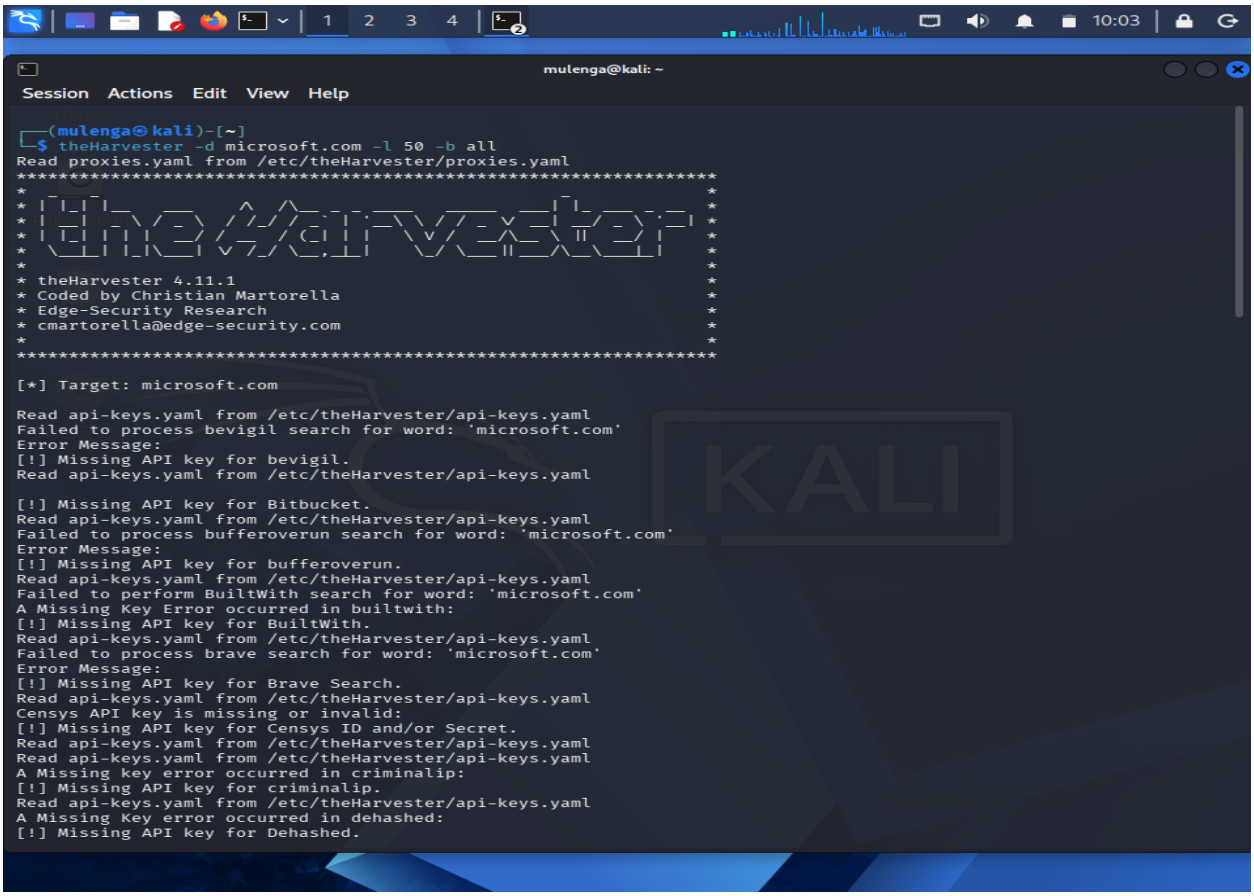


Figure 12 — Start of the all-sources query and source processing.

9. PM5 — Network Discovery with Nmap CLI

Zenmap is the graphical interface for Nmap. The CLI was used as an equivalent for Ping Scan and provides reproducible commands and machine-readable output.

Item	Result
Interface	eth0
Local IP	10.125.198.58/24
Subnet	255.255.255.0
Gateway	10.125.198.83
Command	sudo nmap -sn 10.125.198.58/24
Hosts up	2
Gateway MAC	56-8f-81-33-b9-1b— QEMU Virtual NIC

The -sn option performed host discovery only. No port scan, service-version scan or vulnerability script was run.

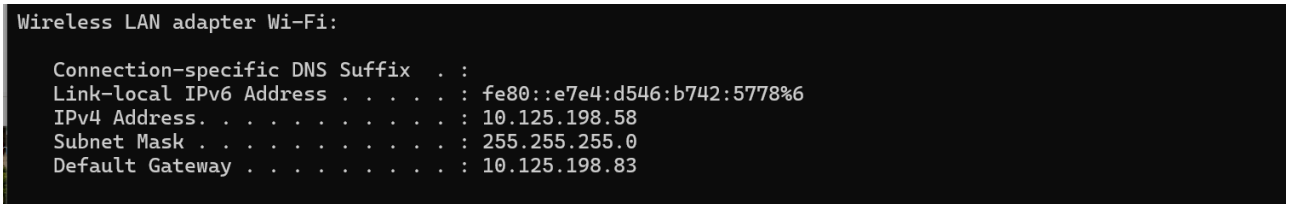


Figure 13— Local IPv4 address and routing table

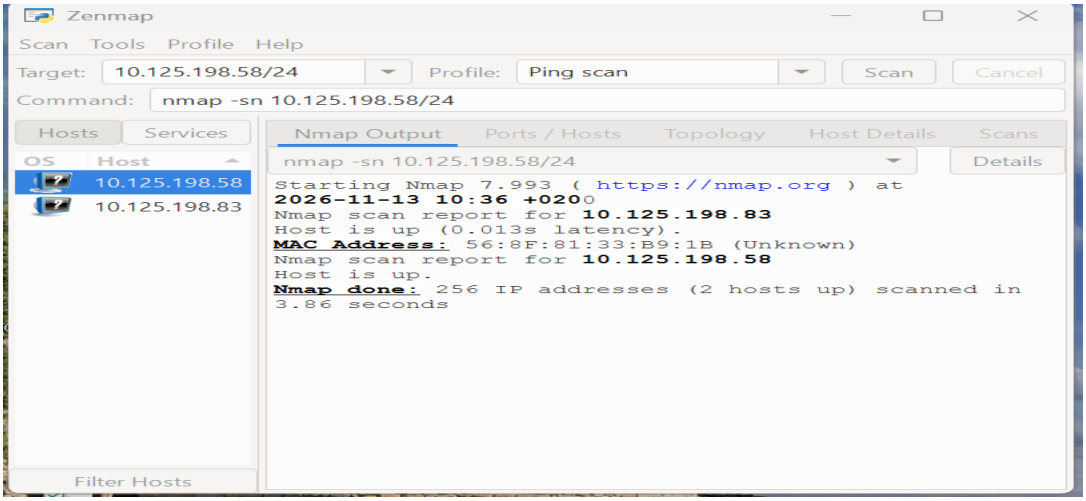


Figure 14— Nmap host-discovery result

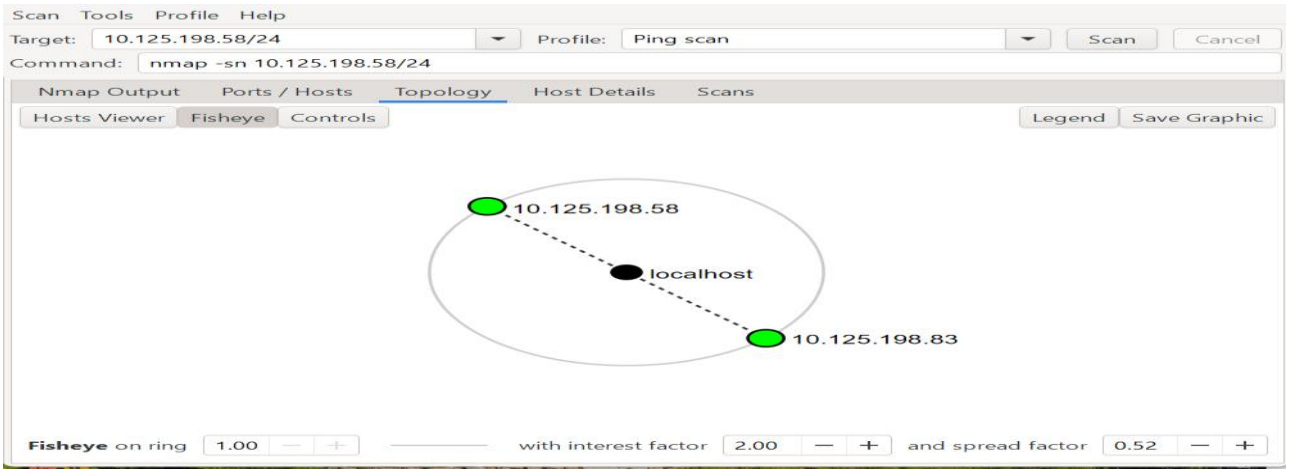


Figure 15 — Topology generated from Nmap output.

10. Risk Analysis

Finding	Potential impact	Level
Public CMS/plugin fingerprints	Can help prioritize targeted security research; requires separate vulnerability validation	Medium
Resolvable server IP and DNS infrastructure	Supports infrastructure mapping	Low
HTTP headers and REST API links visible	Supports application fingerprinting and endpoint discovery	Low
WAF technology identifiable	Reveals a defensive technology but not its rules or bypassability	Low
Large public host inventory for major organizations	May expand the visible attack surface and complicate asset management	Medium
Internet-indexed camera interfaces	May create severe privacy and physical-security exposure if misconfigured	High
Two hosts visible on local virtual LAN	Expected here, but unknown devices should be investigated on managed networks	Low

Risk levels are educational assessments. No finding was exploited or independently confirmed as a vulnerability.

11. Recommendations

1. Maintain current CMS and plugin versions and review exposure of version banners.
2. Review HTTP headers and remove unnecessary technical disclosures while retaining useful security headers.
3. Audit DNS records and decommission obsolete host and service records.
4. Keep ModSecurity enabled, updated, tuned and monitored rather than relying on identification resistance.
5. Maintain an accurate external asset inventory and review certificate-transparency-derived subdomains.
6. Require authentication, network segmentation and VPN access for camera systems; never expose management interfaces directly to the internet.
7. Perform authorized internal host discovery periodically and investigate unknown devices.

8. Redact personal data, credentials, IP addresses and MAC addresses from public repositories when disclosure is unnecessary.
9. Document written authorization, target scope, time window and permitted techniques before every assessment.

12. Conclusion

The project demonstrated how several tools contribute different pieces to a reconnaissance picture. PM1 identified domain, DNS, web technology, HTTP and WAF information. PM2 demonstrated targeted search operators and highlighted the legal difference between discoverability and authorization. PM3 mapped a public domain-to-email relationship. PM4 showed both the value and limitations of multi-source passive OSINT. PM5 used Nmap CLI to identify two live hosts on the student's own virtual LAN and document their addresses in a simple topology.
The project did not include exploitation. Findings were treated as observations requiring authorization and further validation. The strongest practical lesson was that ethical scope, accurate reporting and safe handling of evidence are as important as running the tools.

Appendix A — Evidence Inventory

Module	Evidence
PM1	Six command outputs and screenshots
PM2	Two mathematics search screenshots; camera methodology retained privately and excluded from public release
PM3	Setup, entity, transform-menu and result screenshots
PM4	Help, Baidu and all-sources outputs/screenshots
PM5	IP/routing, Nmap XML/text, scan screenshot, MAC output and generated topology

End of report.